Cibersegurança

Repositório Central de Concursos de TIC · UFRRJ & Transpetro 2026

Caderno Consolidado de Cibersegurança — teoria completa, mnemônicos e pegadinhas de prova.

Gerado automaticamente em 13/11/2026.

Sumário

• Cibersegurança — T01: Fundamentos, Princípios Básicos e Controle de Ativos
• Cibersegurança — T02: Arquitetura de Firewalls, Tipos e Regras de Perímetro
• Cibersegurança — T03: Criptografia, Certificação e Assinatura Digital
• Cibersegurança — T04: Gestão de Vulnerabilidades, Pentest, CVE/CVSS e MITRE ATT&CK
• Cibersegurança — T05: Gestão de Riscos Cibernéticos, Normas ISO 27000 e Políticas (PSI)
• Cibersegurança — T06: Gestão de Identidades (IAM), MFA, SSO, OAuth 2.0, OpenID e Zero Trust
• Cibersegurança — T07: Continuidade de Negócios, Rotinas de Backup e Disaster Recovery
• Cibersegurança — T08: Softwares Maliciosos, Técnicas de Ataque e Engenharia Social
• Cibersegurança — T09: Monitoramento, IDS/IPS, SIEM, SOAR e Honeypot

---

Cibersegurança — T01: Fundamentos, Princípios Básicos e Controle de Ativos

■ Visão Geral

A Segurança da Informação (SI) tem como objetivo proteger os ativos de informação contra acessos não autorizados, alterações indevidas ou indisponibilidade. Toda a arquitetura de defesa repousa sobre a Tríade CID e sobre os princípios estruturais de engenharia de segurança estabelecidos por Saltzer e Schroeder.

Do que se trata?

Trata-se do alicerce conceitual de segurança: as propriedades fundamentais da informação (Confidencialidade, Integridade e Disponibilidade — Tríade CID), os princípios estendidos (Autenticidade e Não-Repúdio) e as boas práticas de projeto seguro de sistemas computacionais.

Por que cai em prova?

As bancas, especialmente a CESGRANRIO, adoram cobrar:

• A distinção entre ataques passivos (que violam a confidencialidade) e ataques ativos (que violam a integridade e disponibilidade).

• Os princípios clássicos de design de Saltzer & Schroeder, com foco em "Economia de Mecanismo" e "Padrão Seguro (Fail-safe Defaults)".

• Medidas fundamentais de proteção de ativos como **Hardening** e redução da superfície de ataque.

Como as partes se conectam?

```
flowchart TD
SI["Segurança da Informação"] --> CID["Tríade Fundamental (CID)"]
CID --> C["Confidencialidade<br>(Criptografia / Controle de Acesso)"]
CID --> I["Integridade<br>(Hashes / Assinatura Digital)"]
CID --> D["Disponibilidade<br>(Redundância / Backups / Resiliência)"]

SI --> Principios["Princípios de Saltzer & Schroeder"]
Principios --> EM["Economia de Mecanismo (Simplicidade)"]
Principios --> FD["Fail-safe Defaults (Bloqueio por Padrão)"]
Principios --> LP["Menor Privilégio (Acesso Mínimo)"]
Principios --> MC["Mediação Completa (Verificar Sempre)"]

SI --> Hardening["Hardening<br>(Redução de Superfície de Ataque)"]
```

Quadro Comparativo: Ataques Passivos vs. Ativos

Característica	Ataque Passivo	Ataque Ativo
	Ação do Atacante	Apenas **observa e monitora** o tráfego sem alterar os dados
	Exemplos Típicos	*Eavesdropping* (escuta), *Sniffing*, análise de tráfego
	Pilar Comprometido	**Confidencialidade**
	Dificuldade de Detecção	Extremamente difícil (não gera ruído perceptível)
	Defesa Primária	Cifragem forte (**Criptografia**)

Princípios de Saltzer e Schroeder (1975)

Estes são os princípios mais recorrentes em concursos para cargos de tecnologia:

■ **Economia de Mecanismo (*Economy of Mechanism*):** O design dos mecanismos de segurança deve ser o mais simples e conciso possível. Interfaces complexas aumentam exponencialmente a probabilidade de erros e brechas de implementação.

■ **Padrão Seguro (*Fail-safe Defaults*):** A concessão de acesso deve basear-se exclusivamente em permissão explícita. Por padrão, a ausência de uma regra deve resultar na negação imediata do acesso (*Default Deny*).

■ **Mediação Completa (*Complete Mediation*):** Toda tentativa de acesso a qualquer recurso deve ser interceptada e validada, sem guardar aprovações tácitas que burlem o controle em requisições subsequentes.

■ **Design Aberto (*Open Design*):** A segurança do mecanismo não deve depender do segredo de como ele funciona (*Security through Obscurity*), mas sim do sigilo de chaves criptográficas e credenciais.

■ **Separação de Privilégios (*Separation of Privilege*):** Sempre que viável, uma operação crítica deve exigir a confluência de múltiplos mecanismos ou aprovações independentes para ser executada.

■ **Mínimo Privilégio (*Least Privilege*):** Usuários e processos devem operar com o conjunto estritamente mínimo de permissões necessárias para o cumprimento de suas rotinas.

■■ PEGADINHA

Pegadinha Clássica: A banca costuma trocar "Economia de Mecanismo" com "Mínimo Privilégio". Memorize: código compacto e design sem complexidade = **Economia de Mecanismo**; limitar permissão de usuário = **Mínimo Privilégio**.

Medidas Básicas de Proteção: Hardening

O **Hardening** (endurecimento de sistemas) é o processo metodológico de reduzir a superfície de ataque de um servidor, computador ou dispositivo de rede:

- Desativação de serviços e daemons desnecessários;
- Fechamento de portas lógicas não utilizadas;
- Remoção de contas padrão, senhas de fábrica e usuários inativos;
- Aplicação contínua de patches de atualização e correções de segurança;
- Configuração de políticas de auditoria e logging detalhado.

■ ALERTA

Hardening é uma medida de configuração proativa que visa fechar vulnerabilidades conhecidas antes de qualquer exploração, e não deve ser confundido com ações reativas de perímetro como bloqueio de pacotes em firewall.

O que separa quem acerta de quem erra?

- **Quem erra:** Acha que ataque passivo pode alterar cabeçalhos ou derrubar servidores; confunde *sniffing* com interceptação ativa.
- **Quem acerta:** Sabe que ataque passivo só ameaça a Confidencialidade e que sua principal barreira protetiva é a criptografia robusta. Lembra de imediato que *default deny* decorre de *Fail-safe Defaults*.

O que revisar e quando?

- **Semanalmente:** Reler a tabela de Ataque Passivo vs Ativo e os 6 princípios de Saltzer & Schroeder.
- **Véspera de Prova:** Lembrar a definição de Hardening e o papel da Tríade CID.

Cibersegurança — T02: Arquitetura de Firewalls, Tipos e Regras de Perímetro

■ **Visão Geral**

Firewalls são componentes centrais da arquitetura de segurança de rede, posicionados estrategicamente para atuar como barreiras de controle de acesso (ACL) entre zonas com diferentes níveis de confiança.

Do que se trata?

Compreende as diferentes gerações e modelos de firewalls: filtros de pacotes sem estado (*Stateless*), firewalls com controle de estado (*Stateful*), firewalls proxy de aplicação (*Application Proxies*), Firewalls de Aplicações Web (*WAF*) e Firewalls de Próxima Geração (*NGFW*).

Por que cai em prova?

A CESGRANRIO costuma explorar:

- A camada OSI em que cada firewall atua.
- A eficiência e baixo custo do filtro de pacotes simples.
- A função de intermediação e inspeção de mensagens do Firewall Proxy na Camada 7.
- O comportamento do protocolo FTP (Ativo vs. Passivo) diante de regras restritivas de firewall.

Tipologia de Firewalls

```
flowchart TD
FW["Famílias de Firewall"] --> L34["Camadas 3 e 4 (Rede e Transporte)"]
L34 --> Stateless["Filtro de Pacotes Stateless<br>Inspeção individual de cabeçalhos IP/Porta"]
L34 --> Stateful["Firewall Stateful<br>Tabela de Estados / Conexões Ativas"]
FW --> L7["Camada 7 (Aplicação)"]
L7 --> Proxy["Firewall Proxy<br>Intermediação profunda de conteúdo"]
L7 --> WAF["WAF<br>Proteção de aplicações HTTP/HTTPS (OWASP)"]
L7 --> NGFW["NGFW (Next-Gen)<br>DPI + IPS integrado + Controle de Aplicação"]
```

Quadro Comparativo entre as Tecnologias

Tipo de Firewall	Camada OSI	O que Inspeciona	Vantagens	Desvantagens
	Filtro de Pacotes (Stateless)	Camadas 3 e 4	IP de origem/destino, Porta, Protocolo e Flags TCP	Altíssimo rendimento, baixíssimo custo computacional
	Stateful (Com Estado)	Camadas 3 e 4 (com estado)	Mantém tabela de conexões ativas (*State Table*)	Permite retorno de tráfego legítimo iniciado de dentro

	Firewall Proxy (Aplicação)	Camada 7	Conteúdo integral da mensagem e cabeçalhos de aplicação	Intermedia a conexão e inspeciona payloads
	Web Application Firewall (WAF)	Camada 7 (Web)	Requisições HTTP/HTTPS, parâmetros GET/POST, cookies	Barra SQL Injection, XSS, Path Traversal e CSRF
	NGFW (Next-Generation)	Camadas 2 a 7	Inspeção profunda de pacotes (*DPI*), assinaturas de IPS e controle de apps	Defesa unificada e identificação de aplicações reais

---

O Caso Crítico: FTP Ativo vs. FTP Passivo

O protocolo FTP utiliza duas portas: porta **21** (conexão de controle) e porta **20** (conexão de dados). O modo de estabelecimento da conexão de dados gera um desafio clássico em firewalls de perímetro:

FTP no Modo Ativo (*Standard*)

■ O cliente abre a conexão de controle saindo de uma porta alta qualquer para a porta 21 do servidor.

■ O cliente envia o comando `PORT` informando em qual porta alta local ele aguardará os dados.

■ **O problema:** O servidor inicia ativamente uma nova conexão de retorno a partir da sua porta 20 em direção à porta alta do cliente.

■ **O bloqueio:** O firewall da estação cliente intercepta a requisição vinda de fora e a descarta por ser uma conexão externa não solicitada.

FTP no Modo Passivo (*PASV*)

■ O cliente inicia a conexão de controle para a porta 21 e envia o comando `PASV`.

■ O servidor abre uma porta alta aleatória e informa esse número de porta de volta ao cliente.

■ O cliente inicia ativamente a conexão de dados da sua máquina em direção à porta alta do servidor.

■ Como ambas as conexões são iniciadas de dentro para fora pelo cliente (*outbound*), o firewall do cliente permite o fluxo normalmente.

> **■■ PEGADINHA**
>
> **Pegadinha da CESGRANRIO:** A banca afirma que o FTP Ativo falha porque a porta 21 foi bloqueada. Falso! A porta 21 funciona normalmente. O problema está na **conexão de dados iniciada pelo servidor (de fora para dentro)** que colide com a regra padrão de negação de tráfego inbound do firewall do cliente.

Web Application Firewall (WAF)

O WAF atua na Camada de Aplicação em frente a servidores web (como Apache, Nginx e IIS). Diferente de roteadores que apenas roteiam pacotes, o WAF decodifica o tráfego HTTP/HTTPS e inspeciona se strings maliciosas estão embutidas em campos de formulários ou URLs.

Ataque Bloqueado pelo WAF: Path Traversal

• **Mecanismo:** O atacante injeta sequências de escape de diretórios como `../../../../etc/passwd` para forçar o servidor web a sair da pasta raiz do site e ler arquivos confidenciais do sistema operacional.

• **Atuação do WAF:** O firewall de aplicação detecta os caracteres de escape de caminho (`../`) e bloqueia a requisição antes que o servidor web a processe.

O que revisar e quando?

• **Semanalmente:** Reler a tabela comparativa de Stateless vs Stateful vs Proxy vs WAF.

• **Véspera de Prova:** Lembrar que no FTP Ativo é o servidor quem tenta abrir a conexão de dados contra o cliente.

Cibersegurança — T03: Criptografia, Certificação e Assinatura Digital

■ Visão Geral

A criptografia é a ciência de proteger informações tornando-as ininteligíveis para terceiros não autorizados. No contexto de concursos de TIC, o foco recai sobre a distinção entre algoritmos simétricos e assimétricos, o funcionamento da assinatura digital e a infraestrutura de chaves públicas (ICP-Brasil).

Criptografia Simétrica vs Assimétrica

Característica	Criptografia Simétrica (Chave Secreta)	Criptografia Assimétrica (Par de Chaves)
	Quantidade de Chaves	**Uma única chave** compartilhada para cifrar e decifrar.
	Velocidade de Processamento	**Muito rápida e leve** (adequada para grandes volumes de dados).
	Maior Desafio	O canal de distribuição da chave secreta precisa ser seguro.
	Principais Algoritmos	**AES** (*Advanced Encryption Standard* - padrão global), DES, 3DES, RC4, Blowfish.

■■ Como funciona o envio em Criptografia Assimétrica?

Se Alice quer enviar uma mensagem **confidencial** para Bob: Alice cifra com a **Chave Pública de Bob**. Apenas Bob conseguirá decifrar, pois apenas ele possui a sua correspondente **Chave Privada**.

Assinatura Digital: Garantia de Autoria e Integridade

A Assinatura Digital é a equivalência eletrônica de uma assinatura de próprio punho com firma reconhecida. Ela garante três propriedades simultâneas: **Autenticidade**, **Integridade** e **Não-Repúdio**.

2.1 Como é gerada a Assinatura Digital?

■ O emissor pega o documento original e aplica uma função de **Hash Criptográfico** (ex.: SHA-256), gerando um resumo único de tamanho fixo (*fingerprint*).

■ O emissor **cifra o Hash com a sua própria Chave Privada**. Esse resumo cifrado é a **Assinatura Digital**.

■ O destinatário recebe o documento e a assinatura. Para validar:

- Decifra a assinatura usando a **Chave Pública do emissor**, obtendo o Hash original.
- Calcula o Hash do documento recebido.
- Se os dois Hashes forem **rigorosamente idênticos**, prova-se que o documento não foi alterado em nenhum caractere (Integridade) e que só poderia ter sido gerado pelo dono daquela chave privada (Autenticidade e Não-Repúdio).

■ A Assinatura Digital por si só NÃO gera Confidencialidade!

A assinatura digital cifra apenas o **Hash do documento**, não o documento inteiro! O documento pode viajar em texto claro. Caso se deseje sigilo além da assinatura, é necessário cifrar o arquivo separadamente.

Certificados Digitais e a ICP-Brasil

Um Certificado Digital é uma **carteira de identidade eletrônica** que vincula uma pessoa, empresa ou servidor web a um par de chaves criptográficas.

- **Natureza do Certificado:** É um **arquivo passivo de dados** (formatos `.crt`, `.cer`, `.pem` baseados no padrão **X.509**), emitido e assinado digitalmente por uma **Autoridade Certificadora (AC)** de confiança. **O certificado NÃO é um programa executável** nem antivírus!
- **O que contém no Certificado:** A **Chave Pública** do titular, o nome da entidade/site, data de validade, número de série e a assinatura digital da AC emissora.
- **ICP-Brasil:** A Infraestrutura de Chaves Públicas Brasileira, instituída pela Medida Provisória 2.200-2/2001:
  - **Autoridade Certificadora Raiz (AC-Raiz):** Gerenciada pelo Instituto Nacional de Tecnologia da Informação (**ITI**). É a base de toda a cadeia de confiança no Brasil.
  - **Tipos de Certificados:**
    - **Tipo A (Assinatura):** A1 (gerado e armazenado por software no próprio computador, validade de 1 ano) e A3 (armazenado em mídia criptográfica física inviolável como Smart Card ou Token USB, validade de até 3 ou 5 anos).
    - **Tipo S (Sigilo / Criptografia):** S1 a S4.

Estrutura Detalhada da ICP-Brasil (MP 2.200-2/2001)

A Infraestrutura de Chaves Públicas Brasileira (ICP-Brasil) foi instituída pela Medida Provisória nº 2.200-2/2001 para garantir a autenticidade, a integridade e a validade jurídica de documentos em forma

eletrônica.

Hierarquia e Atores da ICP-Brasil:

■ **Comitê Gestor da ICP-Brasil:** Órgão vinculado à Presidência da República encarregado de fixar as diretrizes, normas e políticas gerais da certificação digital.

■ **Autoridade Certificadora Raiz (AC Raiz - ITI):** O **Instituto Nacional de Tecnologia da Informação (ITI)** desempenha a função exclusiva de AC Raiz no Brasil.

- Compete privativamente à AC Raiz emitir, expedir, distribuir, revogar e gerenciar os certificados das Autoridades Certificadoras de primeiro nível (imediatamente subsequentes).
- A AC Raiz **NUNCA emite certificados digitais diretamente para o usuário final**.
- O certificado da AC Raiz é o único **autoassinado** da cadeia nacional.

■ **Autoridades Certificadoras (ACs):** Entidades públicas ou privadas responsáveis por emitir, renovar, revogar e publicar certificados digitais de entidades finais (servidores web, profissionais e cidadãos).

■ **Autoridades de Registro (ARs):** Entidades responsáveis pela identificação e autenticação presencial ou biométrica dos solicitantes, recebendo os documentos e encaminhando os pedidos de emissão para a respectiva AC. As ARs **não emitem certificados**.

Tipos e Padrões de Certificados ICP-Brasil

Todos os certificados da ICP-Brasil seguem o padrão internacional **ITU-T X.509 v3**:

Certificados de Assinatura Digital (Série A):

- **A1:** Chaves geradas por software e armazenadas diretamente no computador ou dispositivo móvel do titular. Validade de **1 ano**.
- **A3:** Chaves geradas e armazenadas em hardware criptográfico inviolável dedicado (Smartcard ou Token USB com chip criptográfico FIPS). A chave privada não pode ser exportada nem copiada. Validade de **até 5 anos**.
- **A4:** Chaves geradas e custodiadas em Módulos de Segurança Criptográfica dedicados (**HSM - Hardware Security Module**). Utilizado em aplicações corporativas de altíssimo volume.

Certificados de Sigilo / Confidencialidade (Série S):

- Destinados à cifragem assimétrica de mensagens, e-mails e arquivos confidenciais. Seguem subdivisões análogas (S1 a S4).

■■ PEGADINHA

A Falácia do "Cadeado Seguro" (HTTPS):

O certificado HTTPS garante apenas que o tráfego é criptografado e que o domínio pertence ao detentor cadastrado. A existência de certificado digital válido **NÃO garante que o website seja confiável ou livre de vírus**. Criminosos frequentemente emitem certificados válidos para páginas de *phishing*.

Cibersegurança — T04: Gestão de Vulnerabilidades, Pentest, CVE/CVSS e MITRE ATT&CK

> ■ **Visão Geral**
>
> A segurança cibernética não se sustenta apenas em barreiras estáticas; ela exige auditoria contínua e avaliação da postura defensiva. Compreender os testes de intrusão (*Pentest*), as taxonomias globais de falhas (CVE, NVD, CVSS) e as matrizes de técnicas adversárias (MITRE ATT&CK) é o que diferencia o profissional amador do especialista em infraestrutura segura.

Do que se trata?

Trata-se do ecossistema de avaliação ofensiva e gestão de vulnerabilidades:

- **Pentest (Teste de Intrusão / Ethical Hacking):** Simulação controlada e autorizada de ataques reais para identificar brechas exploráveis antes dos cibercriminosos.
- **Bases de Vulnerabilidades e Padronização:** O catálogo global de identificadores **CVE** (*Common Vulnerabilities and Exposures*) gerido pela MITRE, a base governamental enriquecida **NVD** (*National Vulnerability Database* mantida pelo NIST) e o sistema de pontuação de severidade **CVSS** (*Common Vulnerability Scoring System*).
- **Ferramentas de Varredura:** Scanners de vulnerabilidades de rede e sistemas operacionais como **OpenVAS** (Open Vulnerability Assessment System / Greenbone), **Nessus** e **Nmap**.
- **Framework MITRE ATT&CK:** Base de conhecimento global que cataloga Táticas, Técnicas e Procedimentos (TTPs) reais observados em ataques avançados.

Por que cai em prova?

As bancas (FGV, CESGRANRIO, CEBRASPE e FCC) adoram explorar:

- A distinção entre as modalidades de Pentest: **Black Box** (sem conhecimento prévio), **White Box** (com conhecimento e documentação total) e **Grey Box** (conhecimento parcial).
- As fases cronológicas de um teste de invasão (*Reconhecimento/Footprinting -> Scanning -> Gaining Access -> Maintaining Access -> Clearing Tracks*).
- A diferença exata entre **CVE** (dicionário de identificadores únicos no formato `CVE-AAAA-NNNN`) e **NVD** (base de dados do NIST com análise técnica aprofundada, métricas e impacto).
- As métricas do **CVSS** (Grupo de Métricas Base, Métricas Temporais/Ameaça e Métricas Ambientais) e suas faixas de severidade (Baixa, Média, Alta, Crítica).
- A estrutura do **MITRE ATT&CK**, diferenciando **Táticas** (o "porquê" do adversário, objetivo tático como Acesso Inicial ou Movimentação Lateral) e **Técnicas** (o "como", o método prático de execução).

Como as partes se conectam?

```
flowchart TD
subgraph Ofensiva ["Avaliação Ofensiva (Pentest)"]
```

```
PT["Fases do Pentest"] --> Recon["1. Reconhecimento (OSINT/Footprinting)"]
Recon --> Scan["2. Varredura e Enumeração (Nmap/OpenVAS)"]
Scan --> Exploit["3. Obtenção de Acesso (Exploração de Falhas)"]
Exploit --> Mant["4. Pós-Exploração e Manutenção (Backdoors/Pivot)"]
Mant --> Report["5. Relatório e Mitigação (Documentação Executiva)"]
end

subgraph Padronizacao ["Identificação e Severidade"]
CVE["CVE (MITRE)<br>Identificador Único: CVE-2026-XXXX"] --> NVD["NVD (NIST)<br>Base Enriquecida + CVSS + CPE"]
NVD --> CVSS["CVSS (Score 0.0 a 10.0)<br>Métricas: Base, Ameaça e Ambiental"]
end

subgraph Inteligencia ["Inteligência de Ameaças"]
MITRE["MITRE ATT&CK Matrix"] --> Tactics["Táticas (Objetivos Globais)"]
Tactics --> Techniques["Técnicas e Subtécnicas (Mecanismos Práticos)"]
Techniques --> TTPs["TTPs (Perfil de Grupos APT)"]
end

Scan -.->|Detecta Falhas| CVE
Exploit -.->|Mapeia TTPs| MITRE
```

Quadro Comparativo: As Três Modalidades de Pentest

Modalidade	Conhecimento Prévio do Alvo	Simula Qual Cenário?	Vantagens	Desvantagens
	Black Box (*Caixa Preta*)	**Zero**. Nenhuma informação sobre infraestrutura, IP, código ou topologia.	Atacante externo desconhecido na Internet (*hacker oportunista*).	Alta fidelidade quanto à perspectiva externa e descoberta de ativos expostos.
	White Box (*Caixa Branca*)	**Total**. Acesso a diagramas de rede, IPs, credenciais e código-fonte (*Crystal Box*).	Auditoria de segurança máxima ou atacante interno com privilégios (*SysAdmin desonesto*).	Máxima abrangência; testa cada linha de código, API e configuração de firewall.
	Grey Box (*Caixa Cinza*)	**Parcial**. O auditor recebe credenciais de usuário comum ou topologia básica.	Ataque de funcionário mal-intencionado com acesso limitado ou atacante que já furou o perímetro.	Excelente equilíbrio custo-benefício; foca em quebra de privilégios e movimentação lateral.

Gestão de Vulnerabilidades: CVE, NVD e CVSS

4.1 CVE (*Common Vulnerabilities and Exposures*)

- Criado e operado pela corporação **MITRE**.
- Funciona como um **dicionário público e universal** de falhas de segurança conhecidas.
- Padrão de nomenclatura: `CVE-AAAA-NNNN...` (ex.: `CVE-2021-44228` do Log4Shell).
- Cada registro traz apenas um resumo objetivo da falha, referências de links e o número oficial. **A MITRE não atribui a pontuação CVSS detalhada nem calcula as métricas governamentais.**

4.2 NVD (*National Vulnerability Database*)

- Mantido pelo **NIST** (governo dos EUA).
- Sincroniza com a lista de CVEs da MITRE e **enriquece cada registro** com:
  - Pontuação e vetor analítico **CVSS** detalhado;
  - Lista de plataformas, sistemas operacionais e softwares afetados padronizados via **CPE** (*Common Platform Enumeration*);
  - Guias de correção e patches oficiais.

4.3 CVSS (*Common Vulnerability Scoring System*)

É o padrão global gerido pelo **FIRST** (*Forum of Incident Response and Security Teams*) para mensurar a severidade de uma vulnerabilidade. O índice varia de **0.0 a 10.0**.

Os Três Grupos de Métricas:

■ **Métricas Base (*Base Metrics*):** Representam as características intrínsecas e imutáveis da falha (vetor de ataque: rede, adjacente, local ou físico; complexidade; privilégios necessários; interação do usuário; e impactos na Confidencialidade, Integridade e Disponibilidade).

■ **Métricas Temporais / Ameaça (*Threat Metrics*):** Avaliam a situação atual da falha no mundo real ao longo do tempo (disponibilidade de código exploit funcional, maturidade de relatórios e existência de correções).

■ **Métricas Ambientais (*Environmental Metrics*):** Permitem que a organização adeque a pontuação ao seu contexto local específico (se o servidor está isolado por firewall com ar-gap ou exposto diretamente à Internet).

Faixas de Severidade do CVSS (v3.1 e v4.0):

- **0.0:** Nenhuma (*None*)
- **0.1 a 3.9:** Baixa (*Low*)
- **4.0 a 6.9:** Média (*Medium*)
- **7.0 a 8.9:** Alta (*High*)
- **9.0 a 10.0:** Crítica (*Critical*)

> ■ **ALERTA**
>
> **Evolução para o CVSS v4.0:** O CVSS v4.0 adotou nomenclatura mais clara para as classes de métricas: **CVSS-B** (apenas métricas Base), **CVSS-BT** (Base + Threat), **CVSS-BE** (Base + Environmental) e **CVSS-BTE** (Base + Threat + Environmental). Em provas, preste atenção se o enunciado fala do vetor clássico Base ou se menciona fatores externos de exploração ativa no ecossistema global (Threat).

Ferramentas de Varredura e Auditoria

■ **OpenVAS (Greenbone Community Edition):**

- Scanner de vulnerabilidades open source robusto e focado em conformidade e análise de ativos.
- Baseia-se em testes de vulnerabilidade de rede (NVTs - *Network Vulnerability Tests*) atualizados diariamente via feed de assinaturas.
- Gera relatórios detalhados com níveis de severidade baseados em CVSS e passos de remediação.

■ **Nessus (Tenable):**

- Um dos scanners comerciais proprietários mais populares do mundo corporativo.
- Reconhecido por baixa taxa de falsos positivos e cobertura extensiva de configurações de auditoria e conformidade (CIS Benchmarks).

■ **Nmap (*Network Mapper*):**

- Ferramenta essencial de varredura de portas, descoberta de hosts e detecção de versões de serviços e sistemas operacionais.
- Através de scripts **NSE** (*Nmap Scripting Engine*), realiza testes automatizados de vulnerabilidades preliminares.

O Framework MITRE ATT&CK

O **MITRE ATT&CK** (*Adversarial Tactics, Techniques, and Common Knowledge*) é uma base de conhecimento estruturada em matriz que reflete o comportamento real de cibercriminosos:

- **Táticas (*Tactics*):** Representam a **meta ou objetivo tático** do invasor naquele momento (ex.: *Initial Access*, *Execution*, *Persistence*, *Privilege Escalation*, *Defense Evasion*, *Credential Access*, *Discovery*, *Lateral Movement*, *Collection*, *Exfiltration*, *Impact*).
- **Técnicas (*Techniques*):** Representam a **ação concreta** utilizada para cumprir o objetivo da tática (ex.: dentro da tática *Initial Access*, a técnica pode ser *Spearphishing Attachment* ou *Exploit Public-Facing Application*).
- **Subtécnicas (*Sub-techniques*):** Detalhamento refinado e específico da técnica.
- **Procedimentos (*Procedures*):** Como um grupo criminoso específico (ex.: APT28, Lazarus Group) executa a técnica na prática utilizando scripts e ferramentas reais.

■■ PEGADINHA

Pegadinha Clássica: Confundir **Tática** com **Técnica**.

Lembre-se:

Tática = o "porquê" (o objetivo: *Escalonar Privilégios*).

Técnica = o "como" (o mecanismo técnico: *DLL Sideloading* ou *Sudo Caching*).

O que separa quem acerta de quem erra?

- **Quem erra:** Confunde CVE com NVD; acha que a MITRE calcula CVSS oficial; confunde teste Black Box com ataque real não autorizado (lembre: Pentest ético **sempre tem autorização formal prévia - NDA e Termo de Escopo**).
- **Quem acerta:** Sabe que a MITRE cadastra o CVE e o NIST gerencia o NVD; sabe que CVSS 9.0+ é Crítico; sabe que MITRE ATT&CK organiza Táticas (objetivos) e Técnicas (mecanismos de ataque).

Como memorizar sem decorar?

- **As Fases do Pentest em Mnemônico: R**eza **S**empre **E**m **M**omento **R**uim -> **R**econhecimento, **S**canning, **E**xploração (Acesso), **M**anutenção, **R**elatório.
- **Caixa de Auditoria:**
  - *Black*: No escuro total (Zero conhecimento).
  - *White*: Iluminação completa (Código e arquitetura abertos).
  - *Grey*: Meia-luz (Credencial de usuário comum).

Lição para outras matérias

- **Governança de TIC (ITIL e COBIT):** A gestão de vulnerabilidades e os relatórios de pentest alimentam diretamente o processo de *Gestão de Riscos de TI* e a *Gestão de Mudanças*, pois toda correção crítica exige janela programada de implantação.
- **Redes de Computadores:** O escaneamento de portas via Nmap utiliza os mesmos conceitos de flags TCP (SYN, RST, FIN, ACK) estudados na Camada de Transporte do modelo TCP/IP.

Cibersegurança — T05: Gestão de Riscos Cibernéticos, Normas ISO 27000 e Políticas (PSI)

■ Visão Geral

A segurança da informação é um processo contínuo de gestão estratégica, e não um mero produto tecnológico. Nenhuma organização possui orçamento infinito para eliminar 100% das ameaças. Portanto, a gestão de riscos orienta a alocação inteligente de recursos, balanceando custos e controles defensivos sob as diretrizes formais da Política de Segurança da Informação (PSI) e das normas internacionais da família ABNT NBR ISO/IEC 27000.

Do que se trata?

Abrange a governança, conformidade e metodologia de gestão de riscos cibernéticos:

- **A Família ISO/IEC 27000:** Em especial a **ISO/IEC 27001** (requisitos para o Sistema de Gestão de Segurança da Informação — SGSI), a **ISO/IEC 27002** (código de boas práticas e controles de segurança) e a **ISO/IEC 27005** (diretrizes específicas para a gestão de riscos de segurança da informação).
- **O Ciclo de Gestão de Riscos:** Identificação de ativos, ameaças e vulnerabilidades; análise (qualitativa e quantitativa); avaliação contra os critérios de aceitação; e as 4 estratégias fundamentais de tratamento do risco.
- **Risco Inerente vs. Risco Residual:** A mensuração do risco antes e após a implementação de controles de salvaguarda.
- **Política de Segurança da Informação (PSI):** O documento estratégico de mais alto nível da organização que formaliza regras, responsabilidades, sanções e o compromisso da Alta Direção.

Por que cai em prova?

As bancas de concurso cobram exaustivamente:

- A diferença entre a **ISO 27001** (certificável, traz requisitos normativos no formato "a organização deve...") e a **ISO 27002** (guia prático de recomendações, não certificável isoladamente).
- A nova taxonomia da **ISO/IEC 27002:2022**, que reduziu os controles para **93 controles** agrupados em **4 temas** (*Organizacionais, Pessoas, Físicos e Tecnológicos*).
- As quatro opções formais de **Tratamento do Risco** (*Mitigar/Modificar, Transferir/Compartilhar, Evitar/Eliminar, Aceitar/Reter*).
- A distinção entre **Risco Inerente** (risco bruto natural na ausência de controles) e **Risco Residual** (o risco remanescente após os controles aplicados).
- As características da **PSI**: documento estático de alto nível, aprovado formalmente pela Alta Administração, de cumprimento obrigatório por servidores, terceirizados e colaboradores.

Como as partes se conectam?

```
flowchart TD
subgraph Normas ["Normas da Família ISO/IEC 27000"]
ISO27001["ISO/IEC 27001<br>Requisitos do SGSI (Certificável)"]
ISO27002["ISO/IEC 27002<br>Código de Prática / 93 Controles em 4 Temas"]
ISO27005["ISO/IEC 27005<br>Processo de Gestão de Riscos de SI"]
ISO27001 -.->|Controles do Anexo A| ISO27002
ISO27001 -.->|Metodologia de Risco| ISO27005
end

subgraph ProcessoRisco ["Ciclo de Gestão de Riscos (ISO 27005)"]
Contexto["1. Estabelecimento do Contexto e Critérios"] --> Ident["2. Identificação dos Riscos (Ativos, Ameaças, Falhas)"]
Ident --> Analise["3. Análise dos Riscos (Qualitativa vs Quantitativa)"]
Analise --> Avaliacao["4. Avaliação dos Riscos (Comparação com Apetite ao Risco)"]
Avaliacao --> Tratamento["5. Tratamento dos Riscos"]

Tratamento --> Mitigar["Mitigar / Reduzir (Aplicar Controles)"]
Tratamento --> Transferir["Transferir / Compartilhar (Seguro / Terceirizar)"]
Tratamento --> Evitar["Evitar / Descontinuar (Cancelar Atividade)"]
Tratamento --> Aceitar["Aceitar / Reter (Dentro do Limite Tolerável)"]
end

subgraph Governanca ["Instrumento Estratégico"]
PSI["Política de Segurança da Informação (PSI)"] --> NormasInternas["Normas e Procedimentos Operacionais (Pops)"]
PSI --> AltaDir["Aprovação Obrigatória pela Alta Direção"]
end

Tratamento -.->|Gera Controles| PSI
```

O Ciclo de Gestão de Riscos (ISO/IEC 27005)

4.1 A Fórmula Fundamental do Risco

Nas provas de concurso, a relação de risco é sintetizada como:

$$\text{Risco} = \text{Probabilidade de Ocorrência} \times \text{Impacto no Negócio}$$

Ou, sob a ótica de segurança cibernética:

$$\text{Risco} = \text{Ameaça} \times \text{Vulnerabilidade} \times \text{Valor do Ativo}$$

- **Ativo:** Qualquer item que possua valor para a organização (dados, hardware, reputação, pessoas).
- **Ameaça:** Causa potencial de um incidente indesejado (invasores, tempestades, falha de energia, negligência humana).
- **Vulnerabilidade:** Fraqueza ou brecha em um ativo ou controle que pode ser explorada por uma ameaça (software desatualizado, ausência de backup, senha fraca).
- **Impacto:** O dano concreto aos objetivos institucionais caso a vulnerabilidade seja explorada.

> ■ **ALERTA**
>
> **Ameaça não é Risco!** Ameaça é o agente/evento externo; Vulnerabilidade é a fragilidade interna. O Risco só existe quando **uma ameaça concreta encontra uma vulnerabilidade correspondente em um ativo que possui valor real**. Sem vulnerabilidade, a ameaça não gera risco!

4.2 Análise Qualitativa vs. Análise Quantitativa

- **Qualitativa:** Utiliza escalas descritivas ou ordinais (*Muito Baixo, Baixo, Médio, Alto, Muito Alto*) mapeadas em matrizes de probabilidade e impacto. É mais rápida, intuitiva e amplamente adotada.
- **Quantitativa:** Atribui valores numéricos monetários precisos aos eventos:
  - **AV (*Asset Value*):** Valor financeiro do ativo.
  - **EF (*Exposure Factor*):** Percentual de perda sofrido pelo ativo em caso de desastre (ex.: 40%).
  - **SLE (*Single Loss Expectancy*):** Perda esperada para um único evento ($SLE = AV \times EF$).
  - **ARO (*Annualized Rate of Occurrence*):** Taxa de ocorrência anual estimada (ex.: 0.5 para um evento a cada 2 anos).
  - **ALE (*Annualized Loss Expectancy*):** Perda anualizada esperada ($ALE = SLE \times ARO$).

4.3 As 4 Opções Canônicas de Tratamento do Risco

Após avaliar o risco e compará-lo com o **Apetite ao Risco** da alta administração, a equipe deve selecionar uma das quatro ações:

■ **Mitigar / Reduzir (*Risk Mitigation / Modification*):** Aplicar controles de segurança técnicos, físicos ou administrativos para diminuir a probabilidade da ocorrência ou amortecer o seu impacto (ex.: instalar firewall, aplicar criptografia, treinar funcionários).

■ **Transferir / Compartilhar (*Risk Transfer / Sharing*):** Repassar o encargo financeiro ou operacional do risco a terceiros (ex.: contratação de apólice de seguro contra ataques cibernéticos ou terceirização de datacenter com garantia em contrato/SLA).

■ **Evitar / Eliminar (*Risk Avoidance*):** Decidir não iniciar ou descontinuar a atividade, projeto ou sistema que gera a exposição ao risco inaceitável (ex.: desativar um serviço legado obsoleto que não recebe mais suporte).

■ **Aceitar / Reter (*Risk Acceptance / Retention*):** Manter o risco sob monitoramento deliberado e formal sem aplicar novos controles adicionais, quando o custo da salvaguarda for superior ao dano potencial ou

quando o risco residual estiver estritamente dentro da tolerância aceita pela gestão.

■■ PEGADINHA

Pegadinha Clássica: A banca sugere que "ignorar o risco" é o mesmo que "aceitar o risco". Falso! A aceitação do risco exige uma **decisão formal e consciente da Alta Administração**, devidamente documentada no plano de tratamento de riscos. Nunca se trata de negligência tácita.

4.4 Risco Inerente vs. Risco Residual

• **Risco Inerente (*Inherent Risk*):** O nível de risco existente em seu estado puro, antes de qualquer controle ou contra-medida preventiva ser aplicada.

• **Risco Residual (*Residual Risk*):** O risco remanescente que continua existindo após a aplicação bem-sucedida das salvaguardas e controles de segurança. Nenhum sistema atinge "Risco Residual Zero".

Normas ISO/IEC: 27001 e 27002 (Edição 2022)

ABNT NBR ISO/IEC 27001

• Norma **certificável internacionalmente**.

• Estabelece os requisitos para o planejamento, implementação, manutenção e melhoria contínua de um **SGSI** (*Sistema de Gestão de Segurança da Informação*).

• Adota a estrutura de alto nível das normas ISO (cláusulas 4 a 10) baseada no ciclo contínuo de melhoria **PDCA** (*Plan, Do, Check, Act*).

ABNT NBR ISO/IEC 27002:2022 (A Nova Estrutura)

A revisão 2022 da ISO 27002 modernizou a taxonomia de segurança. As 14 seções antigas foram sintetizadas em **4 temas integrados**, totalizando **93 controles**:

■ **Controles Organizacionais (37 controles):** Políticas de SI, segregação de funções, responsabilidades da direção, gestão de ativos, classificação da informação, controles de acesso e privacidade.

■ **Controles de Pessoas (8 controles):** Triagem pré-admissional, termos de confidencialidade (NDA), conscientização, treinamento contínuo e responsabilidades após a rescisão de contrato.

■ **Controles Físicos (14 controles):** Perímetro de segurança física, barreiras de entrada, segurança em escritórios e salas de servidores, proteção contra ameaças externas e ambientais (incêndio, inundação).

■ **Controles Tecnológicos (34 controles):** Autenticação de usuários, controles criptográficos, gerenciamento de vulnerabilidades, prevenção contra malware, proteção de redes e desenvolvimento seguro de software.

■ MEMORIZAR

Mnemônico dos 4 Temas da ISO 27002:2022:

O P F T -> **O**rganizacional, **P**essoas, **F**ísico e **T**ecnológico.

A Política de Segurança da Informação (PSI)

A PSI é o documento institucional de mais alto escalão sobre segurança. Ela expressa a vontade formal e o compromisso da alta administração da entidade pública ou empresa.

Características Mandatórias da PSI:

- **Abrangência Universal:** Aplica-se a todos os servidores, estagiários, terceirizados e prestadores de serviço que tenham acesso aos recursos de informação.
- **Aprovação Formal:** Deve ser **obrigatoriamente aprovada e assinada pela Alta Direção** (Diretoria, Presidência ou Reitoria). Sem essa chancela executiva, a PSI não possui força mandatória.
- **Divulgação Ampla e Ciência:** Deve ser tornada acessível a todos os colaboradores, frequentemente exigindo termo assinado de conhecimento e concordância (*Termo de Ciência e Responsabilidade*).
- **Previsão de Sanções:** Deve conter capítulo explícito estipulando que o descumprimento das regras acarretará sanções disciplinares, administrativas e jurídicas proporcionais.
- **Revisão Periódica:** Deve prever intervalo regular de revisão programada (anual ou bianual) ou extraordinária quando ocorrerem mudanças significativas de infraestrutura ou incidentes graves.

O que separa quem acerta de quem erra?

- **Quem erra:** Acha que a ISO 27002 é certificável; confunde risco inerente com risco residual; pensa que terceirizar um serviço elimina o risco (apenas transfere/compartilha o encargo).
- **Quem acerta:** Lembra que a ISO 27001 é quem certifica o SGSI; sabe que a ISO 27002:2022 possui 93 controles em 4 temas (Organizacional, Pessoas, Físico, Tecnológico); sabe que a PSI deve ser formalmente aprovada pela Alta Direção.

Como memorizar sem decorar?

- **As 4 Ações de Tratamento do Risco (TEAM):**
  - **T**ransferir (Seguro/SLA)
  - **E**vitar (Parar atividade)
  - **A**ceitar (Monitorar formalmente)
  - **M**itigar (Aplicar controle técnico)

Lição para outras matérias

- **Legislação (LGPD - Lei 13.709/2018):** O princípio da Segurança (Art. 6º, VII) e a obrigação de medidas técnicas e administrativas aptas a proteger dados pessoais (Art. 46) apoiam-se diretamente na implementação das normas ISO 27001 e na vigência da PSI institucional.
- **Governança de TIC (COBIT e ITIL):** O processo de Gerenciamento de Riscos de TI do COBIT 2019 (*EDM03 - Garantir a Otimização de Riscos*) adota o framework de apetite ao risco da ISO 27005.

NIST Cybersecurity Framework (CSF) — Implementation Tiers

O NIST CSF categoriza a maturidade da governança e gestão de riscos cibernéticos em quatro *Implementation Tiers*:

Tier	Nome	Características Fundamentais

	Tier 1	**Partial (Parcial)**
	Tier 2	**Risk Informed (Informado)**
	Tier 3	**Repeatable (Repetível)**
	Tier 4	**Adaptive (Adaptativo)**

■ Pegadinha Clássica do NIST CSF

Os *Tiers* do NIST não representam níveis de proteção à prova de invasão, e sim o grau de maturidade e formalização dos processos organizacionais de gestão de risco.

Cibersegurança — T06: Gestão de Identidades (IAM), MFA, SSO, OAuth 2.0, OpenID e Zero Trust

■ Visão Geral

No modelo tradicional de rede, a segurança baseava-se em um perímetro físico ("dentro da empresa é confiável, fora não é"). Na era da nuvem e do trabalho remoto, **a Identidade tornou-se o novo perímetro de segurança**. Compreender a arquitetura de Gestão de Identidades e Acesso (IAM), os fatores de autenticação (MFA), os protocolos modernos de federação (SAML, OAuth 2.0, OpenID Connect) e o paradigma Zero Trust é obrigatório em concursos de TIC.

Do que se trata?

Envolve os mecanismos que controlam quem pode acessar o que, quando e como em um ecossistema corporativo:

- **O Ciclo IAAA:** Identificação, Autenticação, Autorização e Auditoria (*Accountability*).
- **Modelos de Controle de Acesso:** DAC (Discricionário), MAC (Mandatório), RBAC (Baseado em Papéis) e ABAC (Baseado em Atributos).
- **Autenticação Multifator (MFA / 2FA):** A combinação mandatória de categorias distintas de comprovação de identidade.
- **Federação e Single Sign-On (SSO):** Mecanismos que permitem login único em múltiplos sistemas distribuídos sem redistribuir credenciais.
- **Padrões Abertos Modernos: SAML 2.0** (baseado em XML), **OAuth 2.0** (framework de autorização via tokens) e **OpenID Connect — OIDC** (camada de autenticação baseada em tokens JWT).
- **Zero Trust Architecture (ZTA):** O modelo do NIST ("Nunca confie, verifique sempre") que elimina a confiança implícita baseada em localização de rede.

Por que cai em prova?

As bancas adoram armadilhas conceituais sobre:

- A distinção entre **Autenticação** (provar quem você é) e **Autorização** (determinar o que você tem permissão para fazer).

• A pegadinha do MFA: **duas senhas ou senha + pergunta secreta NÃO configuram MFA**, pois pertencem à mesma categoria (*conhecimento*).

• A diferença essencial entre **OAuth 2.0** (que é exclusivamente um protocolo de **Autorização Delegada**) e **OpenID Connect** (que é a extensão que provê **Autenticação de Usuário**).

• Os papéis formais do OAuth 2.0 (*Resource Owner, Client, Authorization Server, Resource Server*) e a finalidade do *Refresh Token*.

• Os três pilares fundamentais do **Zero Trust** segundo o NIST SP 800-207 (*Verificação Explícita, Acesso com Menor Privilégio e Pressuposição de Violação/Assume Breach*).

Como as partes se conectam?

```
flowchart TD
subgraph IAM_Core ["Os 4 Pilares do Controle de Acesso (IAAA)"]
Id["1. Identificação<br>(Quem sou eu? Ex: Username)"] --> Authn["2. Autenticação<br>(Prove que é você! Ex: Senha + MFA)"]
Authn --> Authz["3. Autorização<br>(O que você pode fazer? Ex: RBAC/ABAC)"]
Authz --> Aud["4. Auditoria / Accountability<br>(Rastreio de Logs e Não-Repúdio)"]
end

subgraph Federacao ["Federação e Padrões Modernos"]
SSO["Single Sign-On (SSO)"] --> SAML["SAML 2.0<br>(Mensagens XML / Asserções Corporativas)"]
SSO --> OAuth["OAuth 2.0<br>(Autorização Delegada / Access Tokens)"]
OAuth --> OIDC["OpenID Connect (OIDC)<br>(Camada de Autenticação / ID Token JWT)"]
end

subgraph Arquitetura ["Novo Paradigma"]
ZT["Zero Trust Architecture (NIST SP 800-207)"]
ZT --> P1["1. Verificação Contínua e Explícita"]
ZT --> P2["2. Menor Privilégio Rigoroso"]
ZT --> P3["3. Pressupor a Violação (Microsegmentação)"]
end

Authn -.->|Implementa| SSO
Authz -.->|Regulado por| ZT
```

O Ciclo IAAA e os Modelos de Controle de Acesso

Fase	Pergunta Central	O que Realiza?	Exemplo Real
	Identificação	*Quem é você?*	O usuário alega uma identidade perante o sistema.

	Autenticação	*Você é realmente quem diz ser?*	O sistema valida a identidade com base em credenciais ou fatores biométricos.
	Autorização	*O que você pode fazer aqui?*	O sistema concede ou nega permissões para ler, gravar ou executar arquivos.
	Auditoria (*Accountability*)	*O que você fez e quando?*	Registra ações em logs invioláveis para garantir rastreabilidade e não-repúdio.

Os 4 Modelos Canônicos de Controle de Acesso:

■ **DAC (*Discretionary Access Control* - Discricionário):** O proprietário (*owner*) do objeto decide discricionariamente quem pode acessá-lo e com quais permissões (ex.: permissões clássicas de arquivos no Linux com `chmod`/`chown`).

■ **MAC (*Mandatory Access Control* - Mandatório):** O sistema operacional impõe regras fixas baseadas em rótulos de sensibilidade (*Confidencial, Secreto, Ultrassecreto*) e autorizações formais (*clearance*) dos usuários. Nem o dono do arquivo pode alterar as permissões (ex.: SELinux, AppArmor, modelos militares de Bell-LaPadula e Biba).

■ **RBAC (*Role-Based Access Control* - Baseado em Papéis/Funções):** As permissões são vinculadas a **cargos ou papéis** corporativos (ex.: "Analista de TI", "Auditor"), e os usuários são associados a esses papéis. É o modelo padrão corporativo por sua simplicidade de governança.

■ **ABAC (*Attribute-Based Access Control* - Baseado em Atributos):** Modelo dinâmico e refinado que avalia atributos do sujeito (cargo, departamento), do recurso (classificação do dado), da ação pretendida (leitura, escrita) e do contexto ambiental (horário comercial, geolocalização do IP). Utiliza a linguagem padronizada **XACML**.

Autenticação Multifator (MFA / 2FA)

A autenticação forte exige a confluência de fatores de categorias distintas:

■ **Fator de Conhecimento (*Algo que você SABE*):**

• Senhas alfanuméricas, PIN numérico, padrão de desenho em tela, respostas a perguntas de segurança.

■ **Fator de Posse (*Algo que você TEM*):**

• Token físico RSA SecurID, Smart Card criptográfico, celular com aplicativo gerador de códigos temporários (**TOTP** como Google/Microsoft Authenticator), chaves de segurança de hardware **FIDO2 / U2F** (YubiKey), SMS (desaconselhado por risco de *SIM Swap*, mas classificado como posse).

■ **Fator de Inerência / Biometria (*Algo que você É*):**

• Impressão digital, escaneamento de íris, reconhecimento de retina, biometria facial, reconhecimento de voz.

■ **Fatores Suplementares (Contexto / Comportamento):**

• *Onde você está:* Localização física via GPS ou endereço IP de rede corporativa.

• *Algo que você faz:* Cadência e ritmo de digitação no teclado ou dinâmica de movimentação do mouse (*Behavioral Biometrics*).

■■ PEGADINHA

A Pegadinha Mais Cobrada em Concursos:

A empresa exige que o funcionário digite uma **senha complexa** e, em seguida, responda a uma **pergunta secreta** ("qual o nome da sua primeira escola?"). Isso é MFA?

NÃO! Ambas as etapas são fatores de **Conhecimento** (*Algo que você sabe*). Para ser Autenticação Multifator de verdade, os fatores devem obrigatoriamente pertencer a **categorias diferentes** (ex.: Senha [Sabe] + Token TOTP [Tem]).

Federação de Identidades: SAML, OAuth 2.0 e OpenID Connect

6.1 SAML 2.0 (*Security Assertion Markup Language*)

- Protocolo baseado no formato estruturado **XML**.
- Muito utilizado no ecossistema corporativo tradicional para SSO em aplicações corporativas na nuvem.
- Principais atores:
  - **IdP (*Identity Provider*):** O provedor de identidade centralizado que autentica o usuário (ex.: Active Directory / Okta).
  - **SP (*Service Provider*):** A aplicação de destino que consome a asserção e concede acesso ao usuário (ex.: Salesforce, portal institucional).

6.2 OAuth 2.0: O Framework de Autorização Delegada

O OAuth 2.0 **NÃO é um protocolo de autenticação de usuários**, mas sim um **framework de Autorização Delegada**:

- Permite que uma aplicação terceira (o *Client*) acesse recursos protegidos em nome do usuário sem jamais ter acesso à sua senha.
- **Os 4 Papéis do OAuth 2.0:**
  - **Resource Owner (Dono do Recurso):** O usuário final titular dos dados.
  - **Client (Aplicação Cliente):** A aplicação web ou móvel que solicita acesso aos recursos.
  - **Authorization Server (Servidor de Autorização):** O servidor que autentica o Resource Owner e emite tokens de acesso após consentimento.
  - **Resource Server (Servidor de Recursos):** A API que hospeda os dados e valida os tokens antes de entregar as informações.
- **Tokens do OAuth 2.0:**
  - **Access Token:** Token de vida curta (geralmente no formato **JWT** - JSON Web Token), portador de permissões (*scopes*) específicas, apresentado nas requisições HTTP (`Authorization: Bearer <token>`).
  - **Refresh Token:** Token de vida longa, mantido em sigilo, utilizado exclusivamente para obter um novo *Access Token* quando o atual expirar, sem que o usuário precise digitar suas credenciais novamente.

6.3 OpenID Connect (OIDC): A Camada de Autenticação sobre o OAuth 2.0

Como o OAuth 2.0 por si só não informava "quem" era o usuário (apenas concedia permissões anônimas de acesso), criou-se o **OpenID Connect (OIDC)**:

- É uma camada de **identidade e autenticação** construída diretamente sobre o OAuth 2.0.
- Introduz o **ID Token**: um arquivo JSON Web Token (**JWT**) criptograficamente assinado pelo provedor de identidade, que contém afirmações (*claims*) explícitas sobre a identidade do usuário (nome, e-mail,

identificador único `sub`, data de autenticação).

• Disponibiliza o endpoint `/userinfo` para consulta padronizada de perfil.

> ■ **RESUMO**
>
> **Resumo de Prova:**
>
> **OAuth 2.0** = **Autorização** (o crachá de visitante que permite abrir portas específicas da empresa).
>
> **OpenID Connect (OIDC)** = **Autenticação** (o documento de identidade que comprova quem é o visitante).

Arquitetura Zero Trust (*NIST SP 800-207*)

O paradigma tradicional de segurança perimetral ("Modelo Castelo e Fosso") assumia que tudo o que estivesse fisicamente dentro da rede local era confiável. O **Zero Trust** inverte esse raciocínio:

> *"Never Trust, Always Verify" (Nunca confie, verifique sempre).*

Os Três Princípios Fundamentais (NIST SP 800-207):

■ **Verificação Explícita e Contínua:** Autenticar e autorizar continuamente com base em todos os pontos de dados disponíveis (identidade do usuário, localização, integridade do dispositivo, serviço solicitado e anomalias de comportamento).

■ **Uso de Menor Privilégio (*Least Privilege Access*):** Limitar o acesso com mecanismos JIT (*Just-In-Time*) e JEA (*Just-Enough-Access*), políticas adaptativas de controle e proteção de dados.

■ **Pressupor a Violação (*Assume Breach*):** Operar sob a premissa de que invasores já estão presentes no interior da rede. Adotar **microsegmentação** de rede, criptografia de ponta a ponta (em repouso e em trânsito) e telemetria analítica contínua para impedir movimentação lateral.

O que separa quem acerta de quem erra?

• **Quem erra:** Diz que OAuth 2.0 é protocolo de autenticação; diz que senha + PIN é MFA; acha que Zero Trust significa não ter senhas.

• **Quem acerta:** Lembra que OAuth 2.0 é Autorização e OIDC é Autenticação; sabe que MFA exige categorias distintas (Sabe + Tem + É); sabe que Zero Trust pressupõe que a rede interna já pode estar comprometida (*assume breach*).

Lição para outras matérias

• **Redes de Computadores:** A microsegmentação pregada pelo Zero Trust apoia-se no uso avançado de VLANs, firewalls internos stateful e túneis seguros TLS/IPsec.

• **Legislação (LGPD):** O controle rigoroso de acesso e o princípio do privilégio mínimo (RBAC/ABAC) são exigências práticas fundamentais para o cumprimento do princípio da Necessidade (Art. 6º, III da LGPD).

Cibersegurança — T07: Continuidade de Negócios, Rotinas de Backup e Disaster Recovery

> ■ **Visão Geral**
>
> A continuidade de negócios e a resiliência operacional asseguram que, diante de desastres naturais, falhas de hardware ou ataques devastadores de ransomware, a organização seja capaz de restaurar suas operações no menor tempo possível (RTO) e com a menor perda aceitável de dados (RPO).

Do que se trata?

Abrange a taxonomia de backups (Completo, Incremental e Diferencial), as estratégias de armazenamento físico e lógico (Regra 3-2-1), os modelos de computação em nuvem para resiliência (BaaS e DRaaS) e os protocolos de resposta a incidentes para servidores comprometidos.

Por que cai em prova?

As bancas adoram comparar:

- O comportamento do atributo de arquivamento (*archive bit*) entre o backup incremental e o diferencial.
- A velocidade de cópia versus a velocidade e complexidade de restauração de cada tipo de backup.
- A sinonímia corporativa (o backup diferencial é conhecido como **Incremental Cumulativo** em ambientes como Oracle RMAN).
- As medidas corretas de resposta a incidentes diante de servidores invadidos por backdoors ou sequestrados por ransomware.

Matriz de Comparação entre os Tipos de Backup

Tipo de Backup	O que é Copiado?	Altera o Atributo de Arquivamento?	Velocidade do Backup	Velocidade da Restauração
	Completo (*Full*)	Todos os arquivos e diretórios selecionados	**Sim** (limpa o atributo para `0`)	Mais lenta (maior volume de dados)
	Incremental	Apenas os arquivos criados ou modificados desde o **último backup de qualquer tipo**	**Sim** (limpa o atributo para `0` nos arquivos copiados)	Mais rápida (menor volume diário)
	Diferencial	Todos os arquivos modificados desde o **último backup completo**	**Não** (mantém o atributo intacto para acumular no próximo)	Intermediária (o tamanho do arquivo cresce dia a dia)

```
flowchart TD
subgraph Restauracao ["Fluxo de Restauração em Desastre"]
```

```
Full["Backup Completo (Domingo)"]

subgraph Estrategia_Incremental ["Com Incremental"]
Full --> Inc1["Incremental (Seg)"] --> Inc2["Incremental (Ter)"] --> Inc3["Incremental (Qua)"]
end

subgraph Estrategia_Diferencial ["Com Diferencial"]
Full --> Dif["Último Diferencial (Qua)"]
end
end
```

■■ PEGADINHA

Sinonímia de Fornecedor Corporativo: Em ferramentas avançadas corporativas (como Oracle RMAN e Veritas), o backup diferencial é chamado de **Backup Incremental Cumulativo** porque acumula cumulativamente todas as mudanças desde o nível 0 (Full). Não erre achando que se trata de um backup incremental comum!

Estratégias Fundamentais de Proteção

• **A Regra 3-2-1:** Manter pelo menos **3** cópias de qualquer dado vital, armazenadas em pelo menos **2** tipos de mídias distintas (ex.: disco e fita ou nuvem), com pelo menos **1** cópia mantida fora das dependências da empresa (*offsite* ou em nuvem com *air-gap*).

• **A Inutilidade do RAID como Backup:** Arranjos RAID (como RAID 1 ou RAID 5) fornecem apenas **tolerância a falhas físicas de hardware**. O RAID não protege contra erros humanos de exclusão de arquivos, nem contra ransomware, pois a corrupção ou criptografia é replicada em tempo real para os discos espelhados.

• **Testes Periódicos de Restauração:** Um backup só existe de verdade se puder ser restaurado. Políticas de segurança exigem exercícios periódicos de restauração sob pena de o catálogo de fitas ou discos estar corrompido no dia do desastre.

Resiliência em Nuvem: BaaS vs. DRaaS

• **Backup as a Service (BaaS):** Contratação de repositório em nuvem gerenciado para envio e armazenamento de cópias frias de arquivos e bancos de dados. A recuperação envolve baixar os arquivos e instalá-los manualmente em servidores locais.

• **Disaster Recovery as a Service (DRaaS):** Solução avançada de continuidade que mantém servidores virtuais inteiros replicados e configurados na nuvem. Em caso de desastre físico no datacenter local, o DRaaS realiza o **failover automático**, subindo os servidores na nuvem em poucos minutos para manter a empresa operando.

Resposta a Incidentes: Servidor Comprometido e Ransomware

Quando um servidor é invadido por criminosos (com instalação de backdoors em portas como a clássica 31337) ou infectado por ransomware:

■ **Ação Imediata:** Isolar o servidor da rede (desconectar o cabo de rede ou isolar a VLAN) para impedir movimentação lateral.

■ **Preservação de Evidências:** Coletar a imagem forense da memória RAM e do disco antes de qualquer reinicialização.

■ **O que NÃO fazer:** Apenas fechar a porta do backdoor no firewall não elimina o invasor, pois o código malicioso permanece ativo no sistema.

■ **Recuperação Definitiva:** Formatar e reinstalar o sistema operacional a partir de mídia íntegra e confiável, aplicando todos os patches e restaurando dados limpos a partir do backup offsite.

O que revisar e quando?

• **Semanalmente:** Revisar a diferença entre restauração com Incremental vs Diferencial e a pegadinha do "Incremental Cumulativo".

• **Véspera de Prova:** Lembrar a Regra 3-2-1 e a distinção entre BaaS (arquivos) e DRaaS (failover de servidores completos).

Cibersegurança — T08: Softwares Maliciosos, Técnicas de Ataque e Engenharia Social

■ Visão Geral

Os ataques cibernéticos utilizam vetores técnicos (malwares, explorações de rede e DoS) ou vetores humanos (engenharia social) para violar a segurança de sistemas. Compreender as taxonomias de malware e as assinaturas de ataques em rede é indispensável para provas de alto nível.

Do que se trata?

Envolve a classificação completa de malwares (Vírus, Worm, Trojan, Backdoor, Ransomware, Spyware, Rootkit e Botnet), as classes específicas de cavalos de Troia, os métodos de falsificação de identidade (*Spoofing*) e envenenamento de tabelas (*Poisoning*), os ataques de negação de serviço (*DoS/DDoS*) e as táticas de manipulação psicológica.

Por que cai em prova?

A banca CESGRANRIO tem questões recorrentes cobrando:

• O ataque de **SYN Flood** e o mecanismo de conexão meio-aberta (*Half-Open*) do TCP.

• O ataque de **Smurf**, que utiliza requisições ICMP para o endereço de broadcast com IP forjado da vítima.

• A diferença entre **Ransomware** (extorsão por resgate) e **Cryptojacking** (mineração silenciosa de moeda virtual).

• As classes de Trojan consagradas por antivírus (RAT, PSW, Clicker, FakeAV, ArcBomb).

• As técnicas de engenharia social (*Baiting* com isca vs. *Scareware* com medo).

Panorama Geral de Malwares

```
flowchart TD
Malware["Ameaças Maliciosas"] --> Auto["Autopropagáveis"]
Auto --> Worm["Worm<br>Propaga-se sozinho explorando vulnerabilidades"]
Auto --> Virus["Vírus<br>Exige hospedeiro e execução do usuário"]

Malware --> Ocultos["Camuflados e Acesso"]
Ocultos --> Trojan["Trojan (Cavalo de Troia)<br>Parece legítimo, executa payload hostil"]
Trojan --> RAT["RAT: Backdoor para Acesso Remoto"]
Trojan --> PSW["PSW: Roubo de Senhas"]
Trojan --> ArcBomb["ArcBomb: Bomba de Descompressão"]

Malware --> Financeiro["Foco Financeiro"]
Financeiro --> Ransomware["Ransomware<br>Cifra arquivos e exige resgate"]
Financeiro --> Cryptojacking["Cryptojacking<br>Minera criptomoeda furtando CPU/GPU"]
```

Quadro Detalhado de Malwares

Malware	Característica Principal	Vetor de Ação
	Vírus	Não é autônomo. Necessita ser anexado a um arquivo hospedeiro e executado pelo usuário.
	Worm (Verme)	Totalmente autônomo. Não necessita de hospedeiro nem de ação humana.
	Trojan (Cavalo de Troia)	Apresenta-se como um utilitário benéfico, mas esconde carga maliciosa.
	Backdoor	Cria uma porta dos fundos para permitir o retorno do invasor sem autenticação.
	Ransomware	Sequestra o acesso a dados mediante forte criptografia, cobrando resgate em cripto.
	Cryptojacking	Consome os ciclos de processamento (CPU/GPU) da vítima para minerar moedas digitais.
	Rootkit	Conjunto de ferramentas que mascara a presença do atacante no núcleo (*kernel*) do SO.
	Botnet	Rede de computadores zumbis controlados remotamente por um servidor C&C (*Command & Control*).

Ataques à Pilha de Protocolos (TCP/IP)

TCP SYN Flood

• **Conceito:** Explora o handshake de três vias do protocolo TCP.

• **Funcionamento:** O atacante dispara dezenas de milhares de pacotes `SYN` com endereços de IP de origem falsificados (*IP Spoofing*).

• **Efeito:** O servidor responde com pacotes `SYN/ACK` e aloca blocos de memória mantendo as conexões no estado meio-aberto (*Half-Open*). Como o IP de origem era falso, o pacote `ACK` final nunca é enviado. As filas de conexão do servidor esgotam e ele para de atender requisições legítimas.

• **Mitigações:** Ativação de *SYN Cookies*, redução do timeout de conexões half-open e filtros de taxa em firewalls.

Smurf Attack

• **Conceito:** Ataque de amplificação e inundação baseado no protocolo ICMP.

• **Funcionamento:** O invasor envia pacotes `ICMP Echo Request` (ping) direcionados ao endereço de **broadcast** de uma rede intermediária, forjando o endereço IP de origem com o IP da vítima.

• **Efeito:** Todos os computadores da rede intermediária respondem com `ICMP Echo Reply` diretamente contra a máquina da vítima, soterrando sua conexão sob um dilúvio de tráfego.

Técnicas de Varredura de Portas (*Port Scanning*)

• **SYN Scan (Half-Open):** Envia pacote SYN; se o alvo responder SYN/ACK, a porta está aberta. O atacante envia imediatamente um RST para derrubar a conexão antes de completar o handshake, tornando a varredura mais furtiva.

• **Connect Scan:** Completa o handshake completo de três vias (SYN, SYN/ACK, ACK). É mais lento e deixa registros explícitos nos logs de auditoria do alvo.

• **FIN / NULL / XMAS Scan:** Envia pacotes com combinações anômalas de flags TCP para inferir o estado de portas em sistemas Unix/Linux baseando-se na RFC 793.

• **Idle Scan:** Utiliza um host zumbi intermediário para varrer a vítima sem que o endereço IP do atacante seja gravado nos logs.

Engenharia Social: Técnicas de Manipulação

• **Baiting (Isca):** Promete um benefício tangível ou gratuito (filmes, softwares craqueados ou pendrives com etiquetas convidativas deixados em estacionamentos de empresas) para convencer a vítima a executar o arquivo malicioso.

• **Scareware (Terror Psicológico):** Utiliza pop-ups com alertas alarmantes falsos ("Seu computador possui 50 vírus críticos! Clique aqui para comprar a vacina") para manipular a vítima pelo medo.

• **Phishing e Spear Phishing:** Envio de comunicações fraudulentas simulando bancos, órgãos do governo ou fornecedores. O *Spear Phishing* é altamente direcionado a indivíduos específicos dentro de uma corporação.

• **Tailgating / Piggybacking:** Prática de segurança física em que um estranho segue de perto um colaborador autorizado aproveitando a porta de acesso liberada por crachá.

O que revisar e quando?

• **Semanalmente:** Revisar o mecanismo do SYN Flood (esgotamento de half-open) e do Smurf (broadcast ICMP com IP da vítima).

• **Véspera de Prova:** Memorizar as siglas dos cavalos de Troia (RAT = acesso remoto; PSW = senhas).

Cibersegurança — T09: Monitoramento, IDS/IPS, SIEM, SOAR e Honeypot

> ■ **Visão Geral**
>
> A detecção e resposta a incidentes depende de ecossistemas integrados de monitoramento capazes de identificar ameaças em tempo real, correlacionar eventos dispersos na rede e automatizar a contenção de ameaças.

Do que se trata?

Compreende os Sistemas de Detecção e Prevenção de Intrusão (IDS e IPS), as diferenças entre sensores de rede (NIDS) e sensores de host (HIDS), as metodologias de detecção por assinatura versus anomalia, e as plataformas de centralização de eventos como SIEM (*Security Information and Event Management*), SOAR e Honeypots.

Por que cai em prova?

Questões da CESGRANRIO exigem domínio de:

• A distinção fundamental entre o caráter passivo de emissão de alertas do **IDS** versus a atuação em linha (*inline*) com poder de descarte/bloqueio do **IPS**.

• O papel do **SIEM** como a solução corporativa que fornece uma **visão holística** da infraestrutura agregando e correlacionando logs e eventos em tempo real.

• O conceito e a finalidade de armadilhas deliberadas (**Honeypots**).

IDS vs. IPS: O Duelo Clássico de Perímetro

```
flowchart TD
Tráfego["Tráfego de Rede"] --> Router["Roteador de Entrada"]

subgraph Monitoramento_Passivo ["Detecção Passiva (IDS)"]
Router -.->|Espelhamento / SPAN| NIDS["NIDS (Sensor Passivo)"]
NIDS -->|Gera Alerta| Console["Console do Administrador"]
end

subgraph Defesa_Ativa ["Prevenção Ativa (IPS)"]
Router --> NIPS["NIPS (Inline / Em Linha)"]
NIPS -->|Tráfego Limpo| RedeInterna["Rede Interna"]
NIPS -.->|Descarta / Bloqueia| Drop["Pacote Malicioso Descartado"]
end
```

Quadro Comparativo: IDS vs. IPS

Atributo	Intrusion Detection System (IDS)	Intrusion Prevention System (IPS)
	Posicionamento	Fora de banda (*Out-of-band*), via espelhamento de porta (TAP / SPAN)
	Comportamento	**Passivo**: inspeciona cópias do tráfego sem interferir
	Ação ao Detectar	Emite alertas, registra logs e notifica os analistas de segurança
	Impacto na Rede	Nenhum atraso (latência zero no fluxo principal de produção)

Métodos de Detecção: Assinatura vs. Anomalia

Detecção Baseada em Assinatura (*Signature-based*)

- **Mecanismo:** Compara o padrão de bits do tráfego contra uma base de assinaturas previamente conhecidas (ex.: regras do Snort ou Suricata).
- **Vantagens:** Altíssima velocidade de análise e taxa desprezível de falsos positivos para ameaças conhecidas.
- **Limitações:** Totalmente cego para ameaças inéditas (*Zero-Day*) ou variações polimórficas de malwares.

Detecção Baseada em Anomalia (*Anomaly-based / Heuristic*)

- **Mecanismo:** Constrói um perfil de comportamento padrão (*Baseline*) durante um período de aprendizado. Qualquer desvio estatístico relevante (ex.: pico súbito de pacotes SYN, volume atípico de requisições DNS à noite) é marcado como potencial ataque.
- **Vantagens:** Capaz de identificar ataques de dia zero e comportamentos anômalos de negação de serviço.
- **Limitações:** Taxa mais elevada de falsos positivos (ações administrativas legítimas fora do padrão podem acionar o alarme).

Plataformas Corporativas de Segurança

SIEM (Security Information and Event Management)

O SIEM é a solução de software corporativa que atua como o "cérebro analítico" do SOC (*Security Operations Center*):

- **Coleta e Centralização:** Recebe logs e telemetria gerados por múltiplos appliances heterogêneos (firewalls, switches, servidores web, sistemas operacionais e antivírus).
- **Normalização:** Converte registros em formatos diferentes para um padrão comum unificado.
- **Correlação de Eventos:** Conecta eventos aparentemente desconexos (ex.: uma tentativa de login falha no Linux + uma alteração de regra de firewall no roteador) para identificar campanhas de ataque sofisticadas.

• **Visão Holística:** Entrega aos gestores um panorama completo e consolidado da postura de segurança corporativa.

SOAR (Security Orchestration, Automation and Response)

Enquanto o SIEM é focado em agregação analítica e alertas, o **SOAR** foca na **ação automatizada**:

• Executa *Playbooks* pré-programados para responder a ameaças sem intervenção humana (ex.: ao receber um alerta crítico do SIEM, o SOAR instrui o firewall a banir o IP do atacante automaticamente).

Honeypot (Armadilha de Segurança)

• **Definição:** Um recurso computacional (servidor, aplicação ou banco de dados) deliberadamente vulnerável e sem valor operacional real colocado na rede.

• **Objetivo:** Atrair invasores para longe dos servidores de produção, reter o atacante enquanto ele explora o sistema e coletar inteligência forense sobre as novas técnicas, ferramentas e códigos maliciosos utilizados por cibercriminosos.

O que revisar e quando?

• **Semanalmente:** Lembrar que IDS alerta e IPS bloqueia inline; memorizar o papel de correlação de logs do SIEM.

• **Véspera de Prova:** Lembrar que Honeypot é um alvo falso projetado para atrair e estudar atacantes.

■ **Última atualização:** 13/11/2026